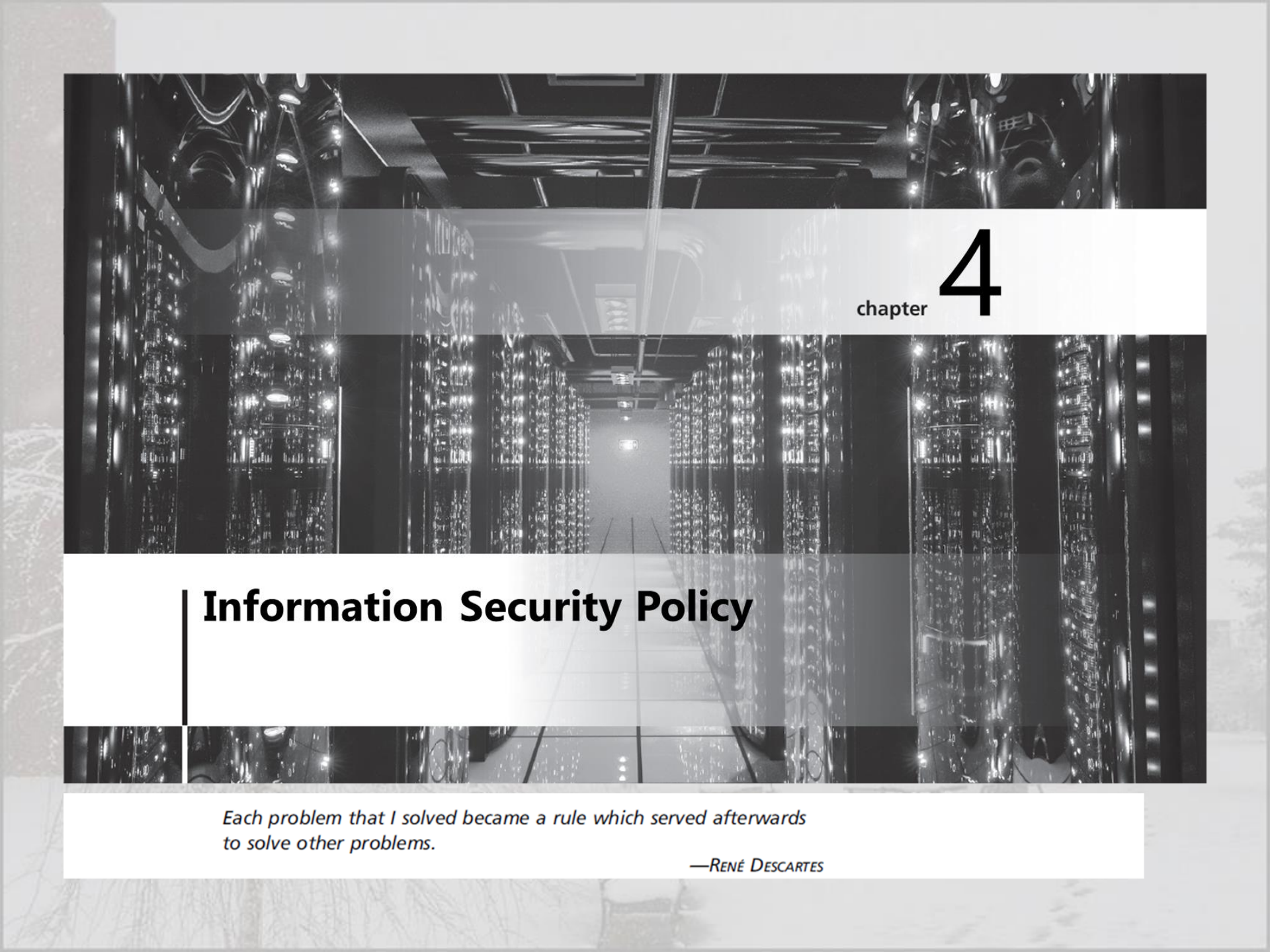




chapter 4

Information Security Policy

Each problem that I solved became a rule which served afterwards to solve other problems.

—RENE DESCARTES

The background image is a faded, grayscale photograph of a modern architectural complex. On the left, a large, multi-story building with a curved facade and a prominent glass-enclosed upper section is visible. In the foreground, a large, leafless weeping tree with dense, drooping branches dominates the left side. To the right, a paved courtyard area contains several outdoor tables and chairs, and a tall, slender lamppost stands near the building. The overall scene is misty or overcast, with a soft, diffused light.

Chính sách Bảo mật

Mục tiêu

- Sinh viên có thể:
 - Xác định chính sách an toàn thông tin và thảo luận về vai trò trung tâm của nó cho chương trình an toàn thông tin thành công
 - Liệt kê và mô tả ba loại chính sách an toàn thông tin chính và thảo luận về các thành phần cơ bản của mỗi loại
 - Giải thích những cần thiết để thực hiện chính sách hiệu quả và những hậu quả mà tổ chức có thể phải đối mặt nếu không thực hiện
 - Thảo luận về quá trình xây dựng, thực hiện và duy trì các loại chính sách bảo mật thông tin

Case Opener

Iris was returning from lunch when she ran into Susan Weinstein, one of RWW's senior account executives, who was accompanied by a man Iris didn't know. Susan introduced him as Bob Watson, a prospective client. As they were chatting, Iris noticed Bob's distracted demeanor and Susan's forced smile and formal manner.

We didn't get the account, Iris realized.

A few minutes later, she saw why the meeting between RWW's account executive and prospective client did not go well. In the cubicle across the hall from Susan's office, two programmers were having lunch. Tim had his feet propped up on the desk. In one hand was a half-eaten hamburger; in the other, he held several playing cards. John had made himself comfortable by taking off his shoes. Teetering over an array of a laptop, tablet, and smartphone was a jumbo soft drink threatening a flood of sugary soda water that could inundate the desk.

Iris went into her office and pulled up the company's policy manual on the company's intranet. She was familiar with most of RWW's policies, but for the actions she had in mind, she needed specifics. But RWW's policy and procedure manual did not contain policies about alerting employees to meetings with prospective clients, or playing cards or eating and drinking in the workplace. What was most disconcerting, though, was that it didn't even contain specifics about practices that supported data protection and other information security objectives.

Before Iris left that evening, she typed up her notes and scheduled an early morning meeting with her boss, Mike Edwards. As she left for home, she thought, *Tim and John playing cards and eating in their office may have cost us a new account. I'll suggest to Mike that it's time for us to reconvene the policy review committee.*

Giới thiệu

- Chính sách là nền tảng thiết yếu của một chương trình bảo mật thông tin hiệu quả:
 - Sự thành công của một chương trình bảo vệ tài nguyên thông tin phụ thuộc vào chính sách được tạo ra và thái độ của cấp quản lý đối với việc bảo mật thông tin trên các hệ thống
 - Bạn, nhà hoạch định chính sách, cần thiết lập quan điểm và nhấn mạnh tầm quan trọng của bảo mật thông tin trong tổ chức của bạn
 - Trách nhiệm chính của bạn là thiết lập chính sách bảo mật tài nguyên thông tin cho tổ chức với các mục tiêu: giảm thiểu rủi ro, tuân thủ luật và quy định, và đảm bảo tính liên tục trong hoạt động, tính toàn vẹn của thông tin và tính bảo mật

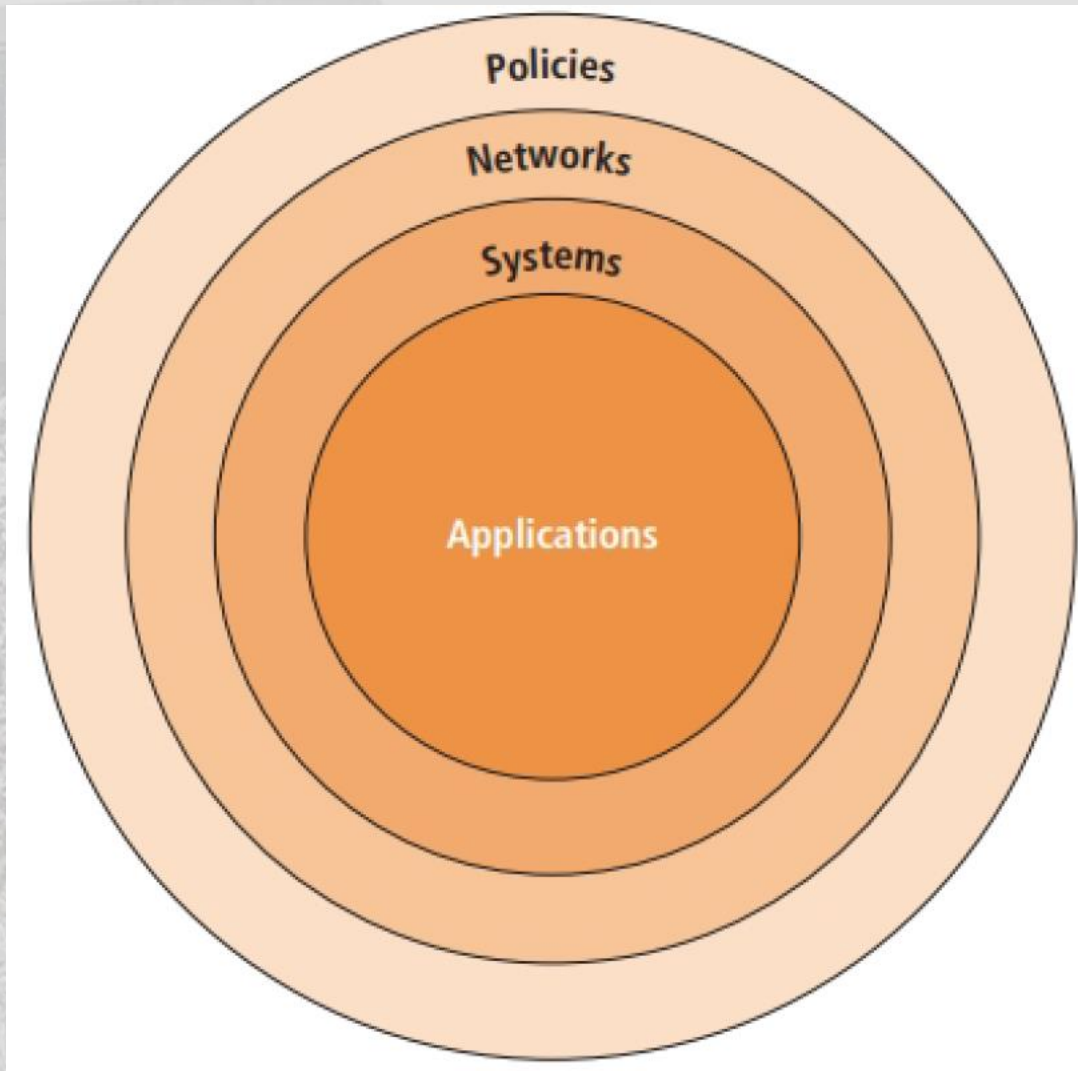
Tại sao là Chính sách?

- Một chương trình bảo mật thông tin có chất lượng thường bắt đầu và kết thúc với chính sách
- Chính sách là phương tiện kiểm soát ít tốn kém nhất và thường khó thực hiện nhất
- Một số quy tắc cơ bản phải được tuân thủ khi định hình chính sách:
 - Chính sách không bao giờ được xung đột với luật pháp
 - Chính sách phải có khả năng giải quyết ở tòa án nếu bị phản đối hoặc sai luật
 - Chính sách phải được hỗ trợ và quản lý phù hợp

Tại sao là Chính sách?

- Theo Bergeron và Bérubé, các gợi ý sau có thể giúp trong việc xây dựng chính sách CNTT và chính sách ATTT:
 - Tất cả các chính sách phải đóng góp vào sự thành công của tổ chức
 - Cấp quản lý phải đảm bảo chia sẻ đầy đủ trách nhiệm về việc sử dụng hợp lý các hệ thống thông tin
 - Người dùng cuối của các hệ thống thông tin cần tham gia vào các bước xây dựng chính sách

Mô hình Mắt bò (Bulls-eye)



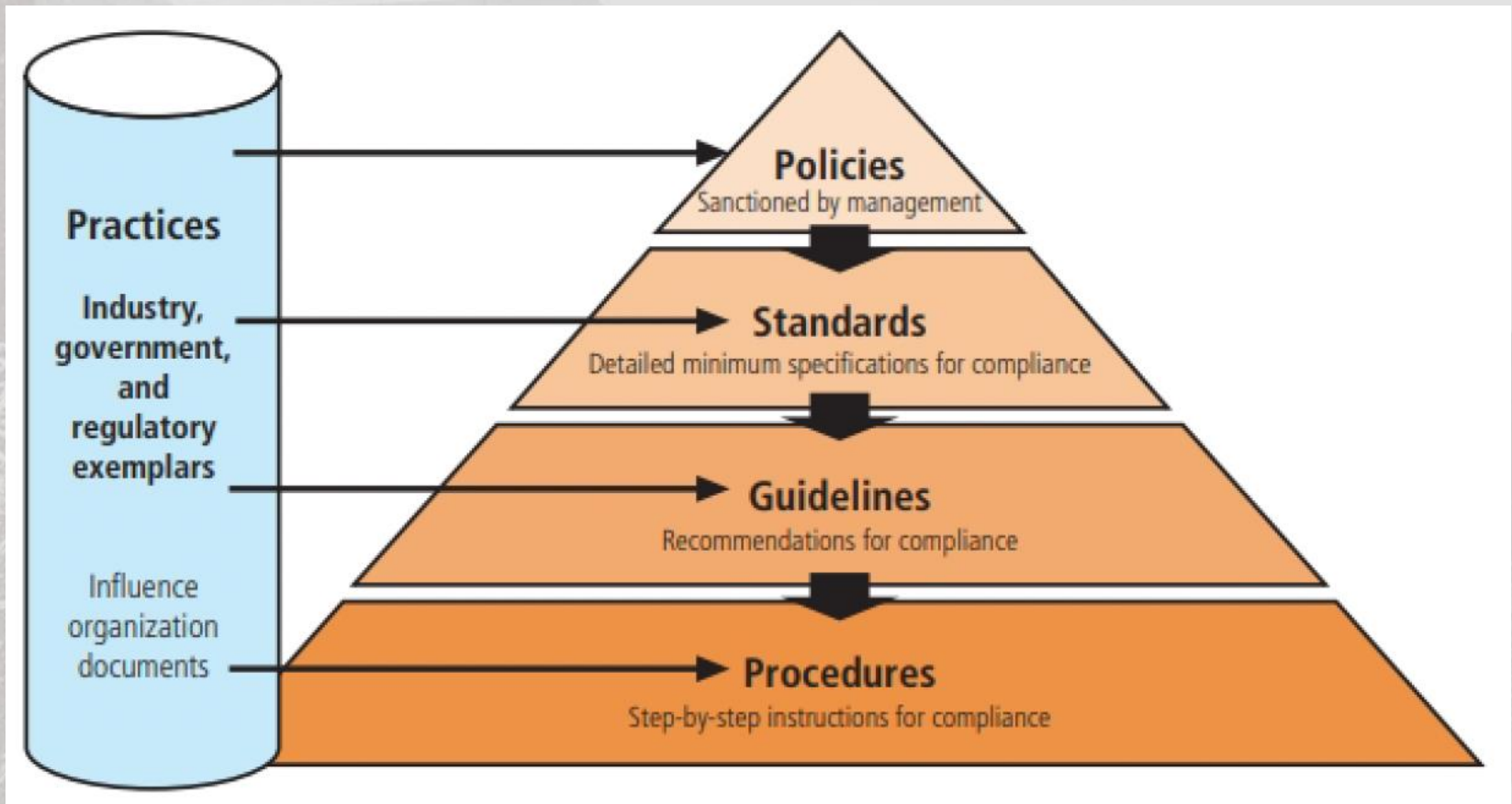
Ra quyết định trung tâm của chính sách

- Các lớp trong mô hình mắt bò:
 - Các chính sách - lớp phòng thủ đầu tiên
 - Mạng - các mối đe dọa gặp đầu tiên trong mạng của tổ chức
 - Hệ thống - máy tính và hệ thống sản xuất
 - Ứng dụng - tất cả các hệ thống ứng dụng
- Các chính sách là tài liệu tham khảo quan trọng cho
 - (i) đánh giá nội bộ
 - (ii) giải quyết các tranh chấp pháp lý về trách nhiệm giải trình của cấp quản lý
- Các chính sách đóng vai trò như một **tuyên bố rõ ràng về ý định của cấp quản lý.**

Chính sách, Tiêu chuẩn và Thực hành

- **Chính sách (Policies)** là một tập hợp các "Hướng dẫn của tổ chức quy định hành vi nhất định trong tổ chức"
- **Tiêu chuẩn (Standards)** là "Tuyên bố chi tiết về những gì phải làm để tuân thủ chính sách, đôi khi được xem như các quy tắc điều chỉnh việc tuân thủ chính sách"
- **Hướng dẫn (Guidelines)** là "Các khuyến nghị không bắt buộc, nhân viên có thể sử dụng làm tài liệu tham khảo để tuân thủ chính sách"
- **Quy trình (Procedures)** là "Các hướng dẫn theo từng bước, được thiết kế để hỗ trợ nhân viên tuân theo các chính sách, tiêu chuẩn và hướng dẫn"
- **Thực tiễn (Practices)** là "Các ví dụ về các hành động minh họa việc tuân thủ các chính sách"

Chính sách, Tiêu chuẩn và Thực hành



Chính sách, Tiêu chuẩn và Thực hành

- Các chính sách xác định những gì có thể làm và không làm, trong khi các tài liệu khác tập trung vào cách làm
- Để các chính sách có hiệu quả, chúng phải được:
 - phổ biến đúng cách
 - đọc
 - hiểu
 - đồng ý
 - thực thi thống nhất

Chính sách, Tiêu chuẩn và Thực hành

- Các chính sách cần sửa đổi và duy trì liên tục
- Để đưa ra một chính sách an toàn thông tin hoàn chỉnh, cấp quản lý phải xác định ba loại chính sách an toàn thông tin:
 - Chính sách Chương trình ATTT doanh nghiệp
 - Các chính sách ATTT về các vấn đề cụ thể
 - Các chính sách cho các hệ thống cụ thể

Chính sách ATTT Doanh nghiệp

- Chính sách ATTT Doanh nghiệp (EISP - Enterprise information security policy) là chính sách ATTT cấp cao, đưa ra định hướng chiến lược, phạm vi và cấp độ cho tất cả các nỗ lực bảo mật của tổ chức
- EISP còn được gọi là chính sách chương trình bảo mật, chính sách bảo mật chung, chính sách bảo mật CNTT, chính sách ATTT mức cao hoặc đơn giản là chính sách ATTT

Tích hợp Sứ mệnh và Mục tiêu của tổ chức vào EISP

- EISP thực hiện một số vai trò quan trọng, nhất là nêu rõ tầm quan trọng của ATTT đối với sứ mệnh và mục tiêu của tổ chức
- EISP không được mâu thuẫn với tuyên bố sứ mệnh của tổ chức
- Tuy nhiên, cần thận trọng nếu một tổ chức có các chính sách chi phối quyền truy cập và đảm bảo rằng việc truy cập đó không gây trở ngại hoặc tạo ra một môi trường làm việc thù địch cho các nhân viên khác

Các thành phần của EISP

- Chính sách bảo mật thông tin doanh nghiệp (EISP) chỉ định trách nhiệm cho các lĩnh vực khác nhau của ATTT, bao gồm việc duy trì các chính sách của ATTT, các thực hành và trách nhiệm của người dùng cuối
- Đặc biệt, EISP hướng dẫn các yêu cầu phát triển, triển khai và quản lý của chương trình bảo đảm ATTT, các yêu cầu này phải được đáp ứng bởi cấp quản lý ATTT và các chức năng bảo mật cụ thể khác

Các thành phần của EISP

- Triết lý của doanh nghiệp về bảo mật
- Cấu trúc của bộ phận ATTT và các cá nhân thực hiện vai trò ATTT
- Tất cả các thành viên của tổ chức (nhân viên, nhà thầu, nhà tư vấn, đối tác và khách tham quan) đều phải chịu trách nhiệm rõ ràng về bảo mật
- Các quy định trách nhiệm về bảo mật dành riêng cho từng vai trò trong tổ chức

Các thành phần của EISP

Thành phần	Mô tả
Mục đích	Trả lời câu hỏi, “chính sách này để làm gì?” nhằm cung cấp các ý định của tài liệu: • Xác định các yếu tố của một chính sách bảo mật tốt • Giải thích nhu cầu bảo đảm an toàn thông tin • Chỉ định các loại bảo mật thông tin khác nhau • Xác định các trách nhiệm và vai trò bảo đảm an toàn thông tin • Xác định các mức độ bảo mật phù hợp với các tiêu chuẩn và hướng dẫn <i>Tài liệu này thiết lập một chính sách và định hướng bảo mật tổng thể cho công ty của chúng tôi. Các bộ phận phải thiết lập các tiêu chuẩn, hướng dẫn và quy trình hoạt động tuân thủ và tham chiếu chính sách này trong khi giải quyết các nhu cầu nhiệm vụ của bộ phận.</i>
Các thành phần	Xác định toàn bộ chủ đề an toàn thông tin trong tổ chức cũng như các thành phần quan trọng của nó. Ví dụ: chính sách có thể nêu rõ: "Bảo vệ tính bí mật, tính toàn vẹn và tính sẵn có của thông tin trong quá trình xử lý, truyền tải và lưu trữ, thông qua việc sử dụng chính sách, giáo dục - đào tạo, và công nghệ" và xác định vị trí và cách thức của các yếu tố đã sử dụng. Phần này cũng có thể đưa ra các định nghĩa hoặc triết lý bảo mật để làm rõ chính sách.
Nhu cầu	Biện minh cho sự cần thiết của tổ chức phải có một chương trình bảo mật thông tin: cung cấp thông tin về tầm quan trọng của ATTT trong tổ chức và nghĩa vụ (pháp lý và đạo đức) để bảo vệ thông tin quan trọng, liên quan đến khách hàng, nhân viên hay thị trường.
Vai trò và trách nhiệm	Cơ cấu nhân sự được thiết kế để hỗ trợ ATTT trong tổ chức. Có thể là mô tả vị trí quản trị cho ATTT và các cá nhân chịu trách nhiệm về ATTT (bộ phận CNTT, quản lý, người dùng) và trách nhiệm về ATTT của họ, bao gồm cả việc duy trì tài liệu này.
Tham khảo	Liệt kê các tiêu chuẩn khác có ảnh hưởng và bị ảnh hưởng bởi chính sách này, bao gồm các luật, các quy định và các chính sách khác.

Chính sách Bảo mật theo vấn đề cụ thể

- Chính sách bảo mật theo vấn đề cụ thể (ISSP - Issue-specific security policy (ISSP) cung cấp hướng dẫn chi tiết, có mục tiêu để hướng dẫn tất cả các thành viên của tổ chức sử dụng tài nguyên, chẳng hạn như một trong các quy trình hoặc công nghệ của tổ chức
- ISSP được thiết kế để điều chỉnh việc sử dụng một số vấn đề về công nghệ hoặc tài nguyên trong tổ chức
- Ở một số tổ chức, ISSP được xem là các chính sách sử dụng hợp lý và có trách nhiệm, mô tả mục đích của chính sách để điều chỉnh việc sử dụng phù hợp
- ISSP phải công bố cho các thành viên của tổ chức rằng mục đích của nó không phải là thiết lập nền tảng cho việc thực thi hành chính hoặc truy tố pháp lý, mà là cung cấp sự hiểu biết chung về các mục đích mà nhân viên có thể hoặc không thể sử dụng tài nguyên.

Chính sách Bảo mật theo vấn đề cụ thể

- ISSP hiệu quả sẽ nhằm thực hiện những việc sau:
 - Nêu rõ những kỳ vọng của tổ chức về cách hệ thống dựa trên công nghệ nên được sử dụng
 - Ghi lại cách kiểm soát hệ thống dựa trên công nghệ đó và xác định các quá trình và bộ phận cung cấp sự kiểm soát này
 - Quy trách nhiệm cho bộ phận có nhân viên sử dụng hệ thống không phù hợp hoặc bất hợp pháp
- ISSP của mọi tổ chức phải:
 - Định rõ các hệ thống cụ thể dựa trên công nghệ
 - Yêu cầu cập nhật thường xuyên
 - Có tuyên bố cụ thể về quan điểm của tổ chức trên một vấn đề

Chính sách Bảo mật theo vấn đề cụ thể

Các chủ đề của ISSP thường gồm việc sử dụng của:

- Thư điện tử, tin nhắn và các ứng dụng liên lạc khác
- Internet, Web và mạng công ty
- Yêu cầu bảo vệ mã độc
- Các phần mềm – phần cứng trong tài sản của tổ chức nhưng không do tổ chức phát hành
- Thông tin của tổ chức trên máy tính không thuộc sở hữu của tổ chức
- Cấm hack hoặc kiểm tra các kiểm soát bảo mật hoặc nỗ lực sửa đổi hoặc tăng đặc quyền
- Sử dụng các thiết bị công ty cho cá nhân hoặc gia đình
- Huỷ/gỡ thiết bị của tổ chức khỏi tài sản của tổ chức
- Thiết bị cá nhân trên mạng của công ty
- Công nghệ của cá nhân trong giờ làm việc
- Công nghệ và mạng viễn thông của tổ chức
- Thiết bị sao chụp và quét (scan)
- Thông tin công ty khi ở bên ngoài cơ sở của công ty
- Truy cập kiểm soát các chứng chỉ/tài khoản của người dùng

Các thành phần của ISSP

- Tuyên bố Mục đích
 - Phạm vi và khả năng áp dụng
 - Định nghĩa công nghệ khắc phục
 - Trách nhiệm
- Quyền truy cập và sử dụng thiết bị
 - Người dùng truy cập
 - Sử dụng công bằng và có trách nhiệm
 - Bảo vệ quyền riêng tư
- Việc sử dụng thiết bị bị cấm
 - Sử dụng gián đoạn hoặc sử dụng sai mục đích
 - Sử dụng phạm tội
 - Tài liệu xúc phạm hoặc quấy rối
 - Vi phạm sở hữu bản quyền, được cấp phép hoặc sở hữu trí tuệ khác
 - Các hạn chế khác

Các thành phần của ISSP

- **Hệ thống quản lý**
 - Quản lý vật liệu được lưu trữ
 - Giám sát của người sử dụng lao động
 - Bảo vệ virus
 - Bảo mật vật lý
 - Mã hoá
- **Vi phạm chính sách**
 - Quy trình Báo cáo Vi phạm
 - Hình phạt cho các Vi phạm
- **Xem xét và sửa đổi Chính sách**
 - Xem xét Chính sách theo lịch trình và Quy trình sửa đổi
- **Hạn chế trách nhiệm pháp lý**
 - Tuyên bố về trách nhiệm hoặc từ chối trách nhiệm

Các thành phần của ISSP

- Các tiếp cận phổ biến:
 - một số tài liệu ISSP độc lập
 - một tài liệu ISSP toàn diện
 - một tài liệu ISSP dạng module thống nhất cho việc tạo và quản lý chính sách
- Cách tiếp cận được khuyến nghị là chính sách theo kiểu từng phần (module), cung cấp sự cân bằng giữa định hướng vấn đề và quản lý chính sách

Chính sách Bảo mật theo hệ thống cụ thể

- Các chính sách bảo mật theo hệ thống cụ thể (SysSP - Systems-Specific Security Policies) đôi khi có giao diện khác và có vẻ giống các quy trình hơn đối với một số người đọc
- Chúng thường có thể có chức năng như các tiêu chuẩn hoặc quy trình để dùng khi cấu hình hoặc bảo trì hệ thống
- SysSP có thể được tách thành:
 - Hướng dẫn quản lý
 - Đặc điểm kỹ thuậtHoặc được kết hợp trong một tài liệu SysSP thống nhất

Hướng dẫn quản lý SysSPs

- Được tạo bởi cấp quản lý để hướng dẫn việc triển khai và cấu hình công nghệ
- Áp dụng cho bất kỳ công nghệ nào ảnh hưởng đến tính bảo mật, tính toàn vẹn hoặc tính sẵn có của thông tin
- Thông báo cho các nhà công nghệ về ý định quản lý

Thông số kỹ thuật của SysSPs

- Hướng dẫn của quản trị viên hệ thống về việc triển khai chính sách quản lý
- Mỗi loại thiết bị có các chính sách riêng
- Có hai phương pháp chung để thực hiện các biện pháp kiểm soát kỹ thuật:
 - kiểm soát truy cập theo danh sách
 - các quy tắc cấu hình

Danh sách Kiểm soát Truy cập (ACL)

- Bao gồm danh sách truy cập người dùng, ma trận và bảng khả năng chi phối các quyền và đặc quyền
- Bảng khả năng chỉ rõ chủ thể và đối tượng mà người dùng hoặc nhóm có thể truy cập
- Các thông số kỹ thuật này thường là các ma trận phức tạp, thay vì danh sách hoặc bảng đơn giản
- Nói chung ACL cho phép quản trị để hạn chế quyền truy cập theo người dùng, máy tính, thời gian, thời lượng hoặc thậm chí một tệp cụ thể

ACLs

- ACL quy định theo 5W1H
 - *(Who) Ai* có thể dùng hệ thống
 - *(What) Người dùng được uỷ quyền có thể truy cập Gì*
 - *(When) Khi nào* người dùng được uỷ quyền có thể truy cập hệ thống
 - *(Where) Người dùng được uỷ quyền có thể truy cập hệ thống từ Đâu*
 - *(How) Người dùng được uỷ quyền có thể truy cập hệ thống Như thế nào*

Quy tắc Cấu hình

- Các quy tắc cấu hình là các mã chỉ dẫn hướng dẫn việc thực thi hệ thống khi thông tin đi qua nó
- Các chính sách dựa trên quy tắc cụ thể hơn đối với hoạt động của hệ thống so với ACL và chúng có thể giải quyết trực tiếp hoặc không với người dùng.
- Nhiều hệ thống bảo mật yêu cầu các tập lệnh cấu hình cụ thể chỉ định hành động nào cần thực hiện trên mỗi tập thông tin mà chúng xử lý.

Các SysSP Kết hợp

- Nhiều tổ chức tạo ra một tài liệu duy nhất kết hợp các yếu tố của cả Hướng dẫn quản lý và Thông số kỹ thuật các SysSP
- Mặc dù tài liệu này có thể hơi khó hiểu đối với người sử dụng chính sách, nhưng rất thực tế khi có hướng dẫn cả hai khía cạnh trên một nơi duy nhất
- Tài liệu như vậy phải trình bày rõ ràng cẩn thận các hành động cần thiết cho mỗi quy trình được mô tả

Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

All Security Policies

Access Control (PS-08-009)

Each agency is responsible for establishing access control measures that limits access (logical and/or physical) to only those individuals that are ...



Accountability of Assets (PS-08-002)

Establishes accountability for all hardware and software acquired using public funds



Appropriate Use of Information Technology Resources (PS-08-003)

Defines the appropriate use of IT resources.



Business Continuity and Disaster Recovery (PS-08-025)

Requires plans to maintain continuity of essential state government operations and services.



Change Management (PS-08-015)

Requirements for a formal change management process.



Cloud Provisioning Policy (PS-22-001)

Governance of cloud-based provisioning according to risk.



Computer Security Incident Management (PS-08-004)

Establishes the process for detecting and responding to security incidents.



Data and Asset Categorization (PS-08-012)

Provides for inventory and classification of state data and information processing systems.



Enterprise Artificial Intelligence Responsible Use (PS-23-001)

Establishes requirements for the use of AI tools within the enterprise.



Enterprise Information Security Policy (PS-08-005)

Commits the State of Georgia to protect information systems and data from unauthorized disclosure, modification, use, or destruction.



Information Security - Risk Management (PS-08-031)

Requires a risk-based approach to information security management



Information Security Controls Policy (PS-17-001)

Improves how security controls are managed within the State's shared-service environment. The Security Control Policy addresses this business challe...



IT Supply Chain Security Controls Policy (PS-20-002)

To provide guidance to State agencies on identifying, assessing, selecting and implementing risk management processes and controls throughout the enterpr...



Media Controls (PS-08-026)

Requirements protection of system media from unauthorized disclosure, modification, destruction or loss



Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

Multi-Factor Authentication Policy (PS-21-002)

The purpose of an Enterprise Multi-Factor Authentication (MFA) Policy is to enable a means of strong authentication for all users with access to informat...



Network Security - Information Flow (PS-08-030)

Requires protection of information traversing networks



Network Security Controls (PS-08-027)

Requires network security controls



Outsourced Facilities Management (PS-08-019)

Establishes requirements over outsourcing data processing facilities



Password Authentication (PS-08-006)

Establishes use of passwords as primary authentication mechanism



Personnel Security (PS-08-014)

Provides for identity verification of IT employees and contractors



Physical and Environmental Security (PS-08-013)

Physical security is an essential element to the overall security of IT resources



Protection from Malicious Software (PS-08-021)

Requires protections against malicious software



Public Access Systems (PS-08-028)

Requires security controls on public facing systems



Reliance on Electronic Records (PS-08-007)

Establishes the State's intent to rely on electronic data as a form of official record and adherence to proscribed records retention requirements



Remote Access (PS-08-023)

Requires protection from risks associated with remote access



Security Awareness Program (PS-08-010)

Establishes a need to increase user security awareness through an awareness and training program



Security Controls Review and Assessment (PS-08-029.02)

Agencies shall periodically review and continuously monitor the management, operational and technical security controls for all information systems to as...



Security Log Management (PS-08-022)

Requires log management practices



Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

Separation of Production and Development Environments (PS-08-020)



Requires separation of production from development and test environments

Systems and Development Lifecycle (PS-08-018)



Requirements for a formal IT lifecycle management program

Third-Party Access (PS-08-011)



Provisions for third-party access to state facilities and information systems

Use of Cryptography (PS-08-024)



Requires the use of cryptographic controls

Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

All Security Standards

Appropriate Use and Monitoring (SS-08-001)

Standards for appropriate use and monitoring of IT resources.



Artificial Intelligence Responsible Use (SS-23-002)

Establishes requirements for the use of AI tools within agency operations.



Authorization and Access Management (SS-08-010)

Requires managed access to state facilities and information resources.



Classification of Personal Information (SS-08-002)

Standards for categorizing personal information.



Computer Operations Center Security (SS-08-016)

Minimum security requirements for computer operations centers.



Concerned Goods and Prohibited Vendors and Services (SS-22-002)

Establishes restrictions on concerned goods, third-party vendors, software and services.



Contingency Planning (SS-08-045)

Requires plans to sustain or recover/restore critical operations in the event of a system disruption or disaster.



Cryptographic Controls (SS-08-040)

Minimum requirements for the use of cryptographic controls.



Cybersecurity Capability Maturity Model (SS-20-001)

Establishes an enterprise Cybersecurity Capability Maturity Model to provide a structure for State agencies to baseline current capabilities in cybe...



Data Categorization - Impact Level (SS-08-014)

Impact Level definitions and standards of information assets



Data Location and Access (SS-15-002)

Requires all data to be processed, stored, transmitted and disposed in the geographical United States.



Data Security - Electronic Records (SS-08-003)

Electronic records are relied upon as official records, must adhere to records retention requirements, and must be protected from unauthorized destructio...



Digital Security Standard (SS-19-002)

Establish a common set of security protocols across all State digital properties (i.e. agency web pages) to ensure the protection of sensitive...



Disaster Recovery - System Backup (SS-08-046)

Backup and recovery procedures for critical software and data.



Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

Electronic Communications Accountability (SS-08-009)

Fixes accountability for content and transfer of information through electronic communications.



Email Use and Protection (SS-08-011)

Standards for appropriate use and security of email.



Facilities Security (SS-08-015)

Incorporates facilities security into overall protection of IT assets.



Generative AI Responsible Use (SS-25-001)

Establishes a framework for responsible experimentation and learning while maintaining appropriate risk management.



Incident Response and Reporting (SS-08-004)

Requirements for information security incident response and reporting



Independent Security Assessments (SS-08-042)

Requires IT systems to be assessed by an independent third-party



Information Security Controls Standard (SS-17-001)

In accordance with the Information Security Control Policy, each agency operating within a shared-service environment is responsible for ensuring that ap...



Information Security Infrastructure (SS-08-005)

Requirements for creating an information security program and infrastructure



Information Security Management Organization (SS-08-006)

Minimum standards for an information security management organization



Information Technology Reporting (SS-08-053)

Annual reporting requirements



International Teleworking and Remote Access (SS-22-001)

This standard establishes minimum security requirements for teleworking and remotely accessing state information systems while traveling internationally...



IP Blocking Standard (SS-17-002)

Establishes criteria for blocking network traffic from IP addresses and IP address ranges at the boundary of the state network.



Log Management Infrastructure (SS-08-036)

Requires monitoring and analyzing systems logs to record events and detect anomalies



Malicious Code Incident Prevention (SS-08-033)

Establishes controls to protect systems against malicious software



Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

Media Protection and Handling (SS-08-043)

Establishes physical, logical, and environmental protection requirements for system media.



Media Sanitization - Vendor Return (SS-08-035)

Establishes standards for sanitization and disposal of all electronic media subject to vendor return



Mobile Device Management (SS-25-003)

Establishes minimum requirements for issuing and managing state-issued mobile devices



Network Access and Session Controls (SS-08-048)

Requires control and monitoring of network sessions



Network Security - Boundary Protection (SS-08-047)

Requires network boundary protection



Non-State Technology and Computing Devices (SS-12-002)

Rules of appropriate use and all other governance regarding information and data security apply to non-State issued technology devices used to access non...



Operational Change Control (SS-08-026)

Requires that changes to operational systems be controlled and monitored



Outsourced IT Services and Third-Party Interconnections (SS-08-044)

Requires third-party adherence to established State security requirements



Password Security (SS-08-007)

Establishes standards for protecting passwords



Personal Identification Verification (PIV) Cards (SS-19-001)

Specifies a reliable PIV system within which a common identity credential can be used to verify a claimed identity and to gain physical and logical ...



Personnel Identity Verification and Screening (SS-08-017)

Standards for verifying identities of state personnel and contractors



Privacy in the Workplace (SS-12-001)

No expectation of privacy shall be assumed when accessing non-public State information resources and assets



Risk Management Framework (SS-08-041)

Adopts the NIST risk management framework



Secure Remote Access (SS-08-038)

Requires protection of systems from risks associated with remote access



Tham khảo

<https://gta-psg.georgia.gov/all-security-policies>

Security Education and Awareness (SS-08-012)

Requires all employees and contractors to attend annual security awareness training



Separate Production and Development Environments (SS-08-031)

Establishes requirements for separating operational environments from test/development environments



Strong Password Use (SS-08-008)

Establishes standards for creating and using strong passwords



Surplus Electronic Media Disposal (SS-08-034)

Establishes statewide standard on disposition of surplus electronic media



System Implementation and Acceptance (SS-08-032)

Requires agencies to establish criteria for accepting a system from development to operations



System Lifecycle Management (SS-08-025)

Requires a formal lifecycle management program for systems in development or operations



System Security Plans (SS-08-028)

Requires data and system owners to create and maintain system security plans



Systems Operations Documentation (SS-08-027)

Requires agencies to document system operational procedures



Teleworking and Remote Access (SS-08-037)

Security requirements for telework and remote access to state information systems



Third Party Service Provider Verification and Screening SS-24-001 (SS-24-001)

This standard establishes the process and requirements for screening and verification of third-party service providers



Third-Party Security Requirements (SS-08-013)

Establishes security requirements for conducting business with contractors, outsourcing vendors and/or other third-parties



Web and E-Commerce Security (SS-08-049)

Requires control and management of web services



Wireless and Mobile Computing (SS-08-039)

Minimum security requirements for wireless network implementation



Hướng dẫn tạo Chính sách Hiệu quả

- Để các chính sách có hiệu quả, chúng phải:
 1. Được xây dựng theo các thông lệ được chấp nhận của ngành và được cấp lãnh đạo chính thức phê duyệt
 2. Được phân phối bằng các phương pháp thích hợp
 3. Được tất cả nhân viên đọc
 4. Được tất cả nhân viên hiểu rõ
 5. Được đồng ý hoặc khẳng định chính thức
 6. Được áp dụng và thực thi thống nhất

Phát triển Chính sách ATTT

- Việc xây dựng chính sách xem như như một dự án gồm ba phần:
 - Phần đầu: chính sách được thiết kế và được viết (hoặc được thiết kế lại và viết lại nếu chính sách lỗi thời)
 - Phần thứ hai: hội đồng quản trị hoặc giám đốc điều hành xem xét và chính thức phê duyệt tài liệu
 - Phần thứ ba: thiết lập các quy trình quản lý để duy trì chính sách trong tổ chức
- Phần đầu tiên là bài tập về quản lý dự án, hai phần sau yêu cầu tuân thủ các thông lệ kinh doanh tốt (good business practices)

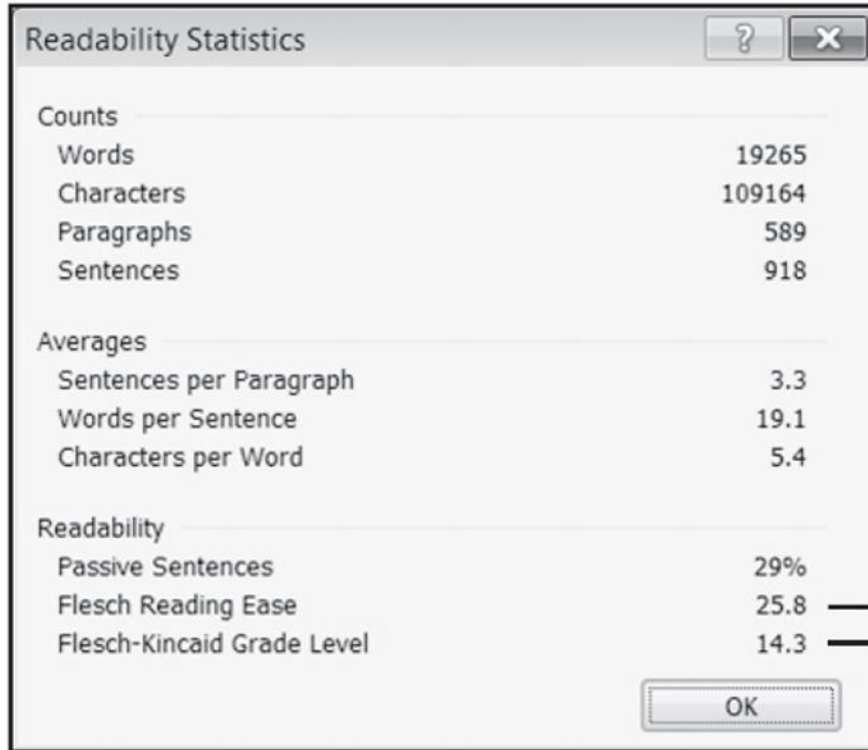
Phân phối Chính sách

- Có thể được thực hiện bằng 2 cách:
 - Phân phối bản in (hardcopy)
 - Phân phối điện tử (electronic)
- Tổ chức cần **đảm bảo chính sách đã thực sự đến tay người dùng cuối**, nếu không thì chính sách đó sẽ không được thực thi.
- Việc phân phối các chính sách đã được phân loại yêu cầu phải **bổ sung các mức độ kiểm soát như gắn nhãn tài liệu, phổ biến chính sách mới, và trong việc thu thập và tiêu hủy các phiên bản cũ** để đảm bảo tính bảo mật của thông tin có trong chính các tài liệu chính sách

Độc Chính sách

- Rào cản độc chính sách của nhân viên có thể nảy sinh do học vấn và ngôn ngữ
- Nhân viên khiếm thị cần được hỗ trợ thêm, hoặc bằng âm thanh hoặc các phiên bản chữ lớn, chữ nổi
- Các tổ chức có nhiều quốc gia cần lưu ý việc đánh giá mức độ đọc và bản dịch cho công dân nước ngoài

Thống kê khả năng đọc



Readability Statistics	
Counts	
Words	19265
Characters	109164
Paragraphs	589
Sentences	918
Averages	
Sentences per Paragraph	3.3
Words per Sentence	19.1
Characters per Word	5.4
Readability	
Passive Sentences	29%
Flesch Reading Ease	25.8
Flesch-Kincaid Grade Level	14.3

Bài đánh giá Dễ Đọc của Flesch đánh giá khả năng viết trên thang điểm từ 1 đến 100. Điểm càng cao thì bài viết càng dễ hiểu. Trường hợp này, văn bản đã được cho điểm 28,6, là phức tạp đối với hầu hết các chính sách nhưng sẽ phù hợp với văn bản đại học. Đối với đa số các tài liệu của công ty, điểm ưa thích từ 60 đến 70.

Bài kiểm tra cấp độ Flesch-Kincaid đánh giá khả năng viết của các cấp học tại Hoa Kỳ. Dù trình độ lớp 13 (sinh viên năm thứ nhất đại học) có thể phù hợp với sách giáo khoa này, nhưng nó quá cao đối với chính sách tổ chức dành cho nhiều đối tượng. Đối với hầu hết các tài liệu công ty, điểm ưa thích từ 7,0 đến 8,0.

Hiểu Chính sách

- Để chắc chắn rằng nhân viên hiểu chính sách, tài liệu phải được viết ở mức độ đọc hợp lý, ít thuật ngữ quản lý và biệt ngữ kỹ thuật nhất
- Bước tiếp theo là sử dụng một số hình thức đánh giá để đánh giá mức độ hiểu của nhân viên về các vấn đề cơ bản của chính sách
- Có thể dùng các câu hỏi và các hình thức kiểm tra khác để đánh giá xem nhân viên có hiểu chính sách (đạt điểm tối thiểu) và nhân viên nào yêu cầu đào tạo bổ sung - nâng cao nhận thức trước khi chính sách có thể được thực thi

Tuân thủ Chính sách

- Việc đồng thuận chính sách được thể hiện qua hành động hoặc sự khẳng định. Đồng thuận bằng hành động xảy ra khi nhân viên thực hiện một hành động theo chính sách, trước khi sử dụng công nghệ hoặc nguồn lực của tổ chức
- Điều gì sẽ xảy ra nếu một nhân viên từ chối tuân thủ chính sách một cách dứt khoát?
Việc không đồng ý với một chính sách tương đương với việc từ chối làm việc và do đó có thể là cơ sở để chấm dứt công việc

Thực thi Chính sách

- Thành phần cuối trong việc thiết kế và thực thi các chính sách hiệu quả là **thực thi công bằng và thống nhất**
- Tương tự thực thi pháp luật, việc **thực thi chính sách phải có khả năng chịu được sự giám sát từ bên ngoài**
- Nếu một nhân viên bị trừng phạt, kiểm duyệt hoặc bị sa thải do từ chối tuân theo chính sách nhưng sau đó có chứng minh rằng các chính sách không được áp dụng hoặc thực thi một cách thống nhất, tổ chức có thể phải đối mặt với các thiệt hại do bị phạt hoặc bồi thường

Phát triển và Thực thi Chính sách sử dụng SecSDLC

- Giống như bất kỳ dự án lớn nào, một dự án phát triển hoặc tái phát triển chính sách cần được lập kế hoạch tốt, được cấp vốn thích hợp và được quản lý tích cực để đảm bảo rằng nó được hoàn thành đúng thời hạn và trong ngân sách
- Một cách để hoàn thành mục tiêu này là sử dụng vòng đời phát triển hệ thống (SDLC)

Giai đoạn Điều tra

- Nhóm phát triển chính sách cần:
 - Có hỗ trợ từ quản lý cấp cao,
 - Có hỗ trợ và tham gia tích cực của người quản lý CNTT, đặc biệt của CIO
 - Trình bày rõ ràng các mục tiêu
 - Sự tham gia của các cá nhân đại diện từ 3 cộng đồng quan tâm có ảnh hưởng bởi chính sách
 - Bộ phận Pháp lý, Nhân sự và người dùng cuối
 - Chỉ định người đứng đầu dự án có tầm vóc và uy tín
 - Có người quản lý dự án có năng lực
 - Đề cương chi tiết của phạm vi dự án phát triển chính sách và ước tính hợp lý cho chi phí và lịch trình của dự án

Giai đoạn Phân tích

- Giai đoạn phân tích sẽ gồm các hoạt động sau:
 - **Đánh giá rủi ro** (risk assessment) hoặc tài liệu đánh giá CNTT (IT audit) mới hoặc gần nhất về các nhu cầu ATTT hiện tại của tổ chức
 - Thu thập các tài liệu tham khảo chính, bao gồm **bất kỳ chính sách nào hiện có**

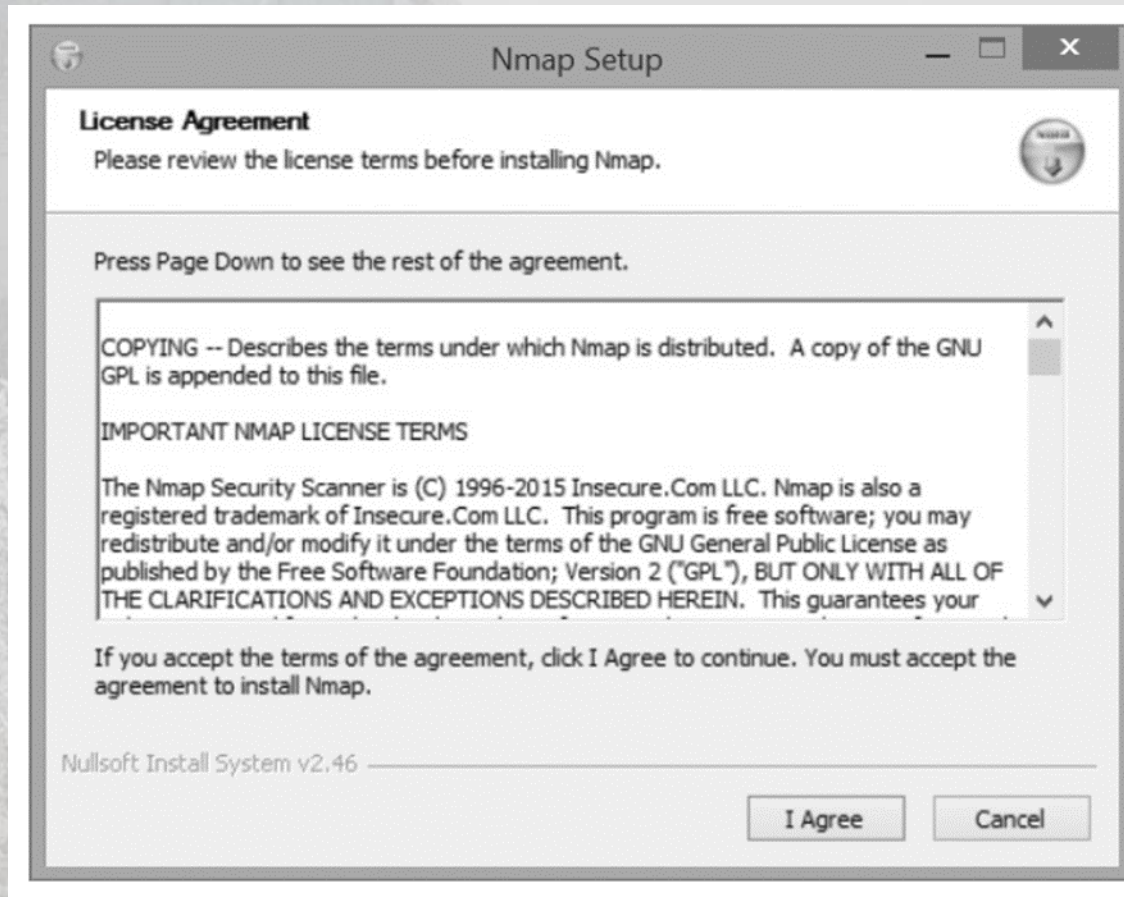
Giai đoạn Thiết kế

- Nhiệm vụ đầu tiên trong giai đoạn thiết kế là **soạn thảo tài liệu chính sách thực tế**
- Mặc dù nhiệm vụ này có thể được thực hiện bởi một ủy ban, nhưng nhiệm vụ này thường được thực hiện bởi một người (tác giả)
 - Có một số tài liệu tham khảo và tài nguyên có sẵn trên Web , thông qua tài liệu chuyên môn và từ các đồng nghiệp và chuyên gia tư vấn
- Tiếp theo, nhóm phát triển hoặc ủy ban xem xét công việc của tác giả chính và đưa ra khuyến nghị sửa đổi
- Sau khi ủy ban phê duyệt tài liệu, nó sẽ được chuyển tới người quản lý hoặc điều hành phê duyệt để ký tên

Giai đoạn Thực thi

- Trong giai đoạn này, nhóm phải lập kế hoạch để phân phối và xác minh việc phân phối của các chính sách
- Các thành viên của tổ chức phải thừa nhận một cách rõ ràng rằng họ đã nhận và đọc chính sách (sự tuân thủ)
- Cách đơn giản nhất để ghi nhận là đính kèm một tờ bìa có nội dung “Tôi đã nhận, đọc, hiểu và đồng ý với chính sách này” kèm *Chữ ký và ngày tháng của nhân viên lưu trên giấy về việc họ đã nhận và đồng ý chính sách*

Thoả thuận bản quyền của người dùng cuối



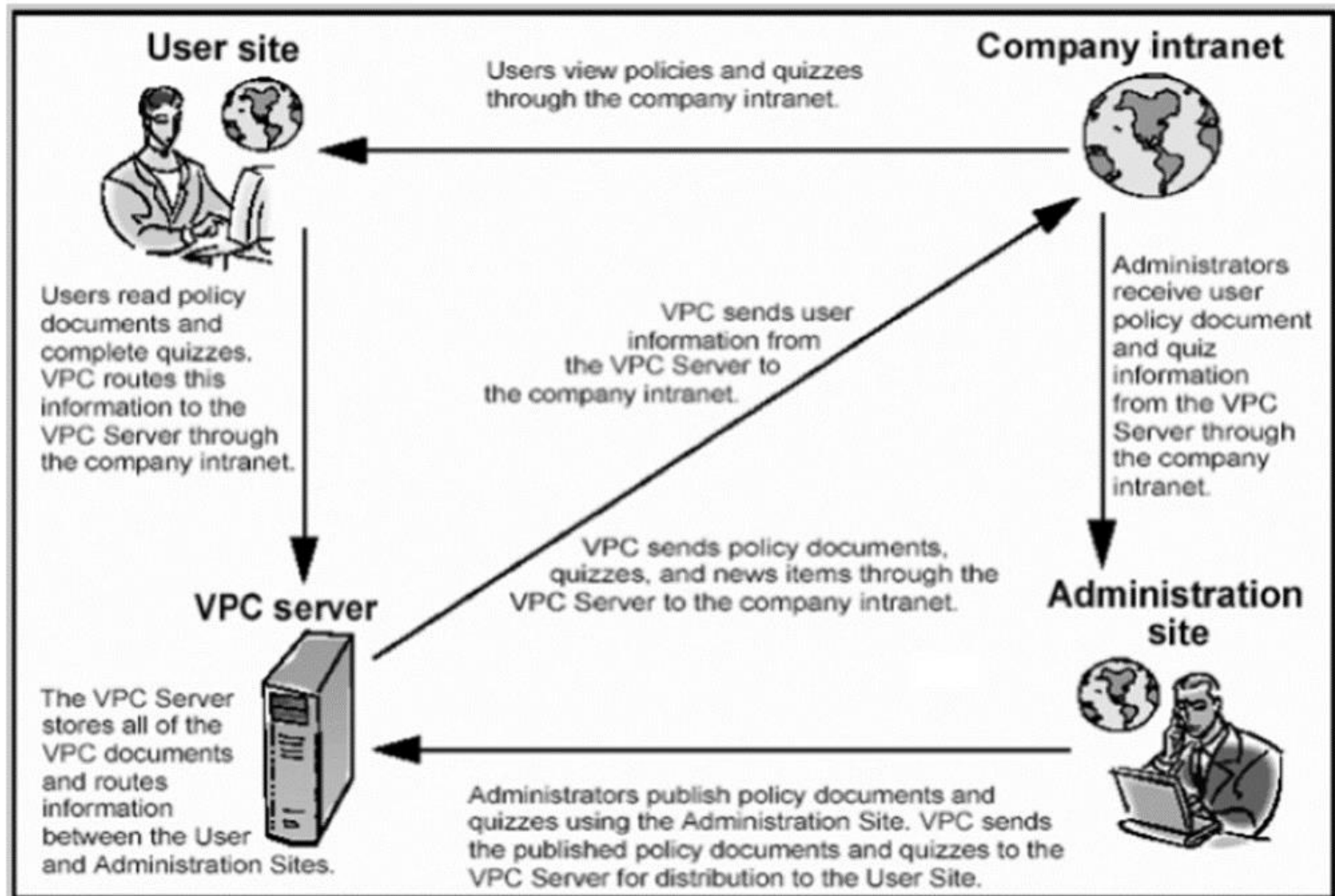
Giai đoạn Duy trì

- Trong suốt giai đoạn duy trì, nhóm phát triển chính sách cần giám sát, duy trì và sửa đổi chính sách khi cần thiết để đảm bảo rằng chính sách vẫn hiệu quả như một công cụ để đáp ứng sự thay đổi của các mối đe dọa.
- Chính sách cần có cơ chế tích hợp để người dùng có thể báo cáo các vấn đề về chính sách, tốt nhất là ẩn danh
- Đánh giá chính sách định kỳ nên được quy định trong quy trình

Các Công cụ Tự động

- Nhu cầu quản lý chính sách hiệu quả đã dẫn đến sự xuất hiện của một loại công cụ phần mềm hỗ trợ phát triển, thực hiện và duy trì chính sách.
- Các công cụ như VigilEnt Policy Center (VPC) giữ cho các chính sách bảo mật bằng mật khẩu trên mạng công ty, và tạo các báo cáo định kỳ cho biết nhân viên nào đã hoặc chưa đọc, có thừa nhận chính sách không
- Các công cụ như VPC cũng nêu rõ người quản lý nào chịu trách nhiệm về chính sách, vì tên của người đó được hiển thị nổi bật trên chính sách, cùng với ngày phê duyệt

VigilEnt Policy Center



Các tiếp cận khác về phát triển chính sách ATTT

- Một số tiếp cận khác để phát triển chính sách ATTT như:
 - Các Chính sách ATTT dễ thực hiện (Information Security Policies Made Easy)
 - NIST SP 800-18, Rev.1: Hướng dẫn phát triển các kế hoạch bảo mật cho các hệ thống thông tin Liên bang (Guide for Developing Security Plans for Federal Information Systems)

Nhà Quản trị Chính sách (Policy Administrator)

- Chính sách cũng tương tự như các hệ thống thông tin và các dự án ATTT, **phải có người đứng đầu và một người quản lý**
- Vị trí người đứng đầu chính sách kết hợp với vị trí quản lý được gọi là nhà quản trị chính sách (Policy Administrator)
- Thông thường, người này là một nhân viên cấp trung, người có trách nhiệm tạo, sửa đổi, phân phối và lưu trữ chính sách

Xem xét lịch trình

- Trong môi trường thay đổi, chính sách có thể duy trì hiệu quả chỉ nếu khi nó được xem xét lại định kỳ về tình trạng hiện tại và độ chính xác, và được sửa đổi để giữ cho nó luôn cập nhật
- Bất kỳ tài liệu chính sách nào cũng đều chứa lịch trình để xem xét cho phù hợp
- Chính sách thường phải được xem xét tối thiểu hàng năm

Xem xét Quy trình và Thực hành

- Để tạo điều kiện thuận lợi cho việc xem xét chính sách, người quản lý chính sách nên thực hiện một cơ chế sao cho các cá nhân có thể dễ dàng đưa ra các đề xuất sửa đổi chính sách và các tài liệu liên quan khác
- Các phương pháp khuyến nghị có thể bao gồm e-mail, phiếu công việc hoặc hộp nhận thư ẩn danh
- Một khi chính sách được đưa ra để xem xét, tất cả các ý kiến cần được kiểm tra và các thay đổi do ban quản lý phê duyệt nên được thực hiện

Chính sách và Ngày xem xét

- Ở một số tổ chức, các chính sách được soạn thảo và ban hành mà không có ngày tháng, khiến người dùng chính sách không biết về độ tuổi hoặc trạng thái của chính sách
- Thực hành kiểu này có thể tạo ra các vấn đề, bao gồm cả các vấn đề pháp lý, nếu nhân viên tuân thủ chính sách lạc hậu
- Lý tưởng, tài liệu chính sách nên bao gồm ngày xuất xứ, cùng với ngày sửa đổi, nếu có
- Một số chính sách có thể cần “điều khoản ngừng hoạt động”, đặc biệt nếu chúng điều chỉnh việc sử dụng thông tin cho một liên kết ngắn hạn với các doanh nghiệp hoặc các cơ quan bên thứ hai

Lưu ý cuối về Chính sách

- Như đã đề cập trước đó, mặc dù các chính sách có thể giúp các tổ chức tránh kiện tụng, nhưng chức năng đầu tiên và quan trọng nhất của họ là thông báo cho nhân viên về những hành vi được và không được chấp nhận trong tổ chức.
- Việc xây dựng chính sách nhằm cải thiện năng suất của nhân viên và ngăn ngừa các tình huống gây bối rối có thể xảy ra
- Trong thực tế, hầu hết nhân viên đều muốn làm những gì đúng. Nếu được giáo dục đúng cách về điều gì có thể chấp nhận được và điều gì không, họ sẽ chọn tuân theo các quy tắc để có hành vi chấp nhận được

Tóm lược chương:

- Một chương trình ATTT có chất lượng luôn bắt đầu và kết thúc bằng chính sách.
- Chính sách thúc đẩy hiệu suất nhân sự thông qua việc tăng cường ATTT của các tài sản thông tin của tổ chức.
- Phát triển các hướng dẫn phù hợp cho chương trình ATTT là vấn đề quản lý, không phải là kỹ thuật. Khía cạnh kỹ thuật của chương trình ATTT chỉ là một phần của toàn bộ chương trình và chỉ nên thực hiện sau khi cấp quản lý đã tạo lập các chính sách liên quan.
- Mặc dù các chính sách ATTT là phương tiện kiểm soát ít tốn kém, nhưng chúng thường khó thực hiện. Kiểm soát chính sách tiêu tốn thời gian, nỗ lực của nhóm quản lý dành cho việc tạo lập, phê duyệt và truyền đạt, và nỗ lực của các nhân viên tích hợp chính sách vào các hoạt động hàng ngày của mình.

Tóm lược chương:

- Chính sách ATTT phải thoả mãn nhiều tiêu chí:
 - Chính sách không bao giờ được xung đột với luật pháp.
 - Chính sách sách phải có khả năng giải trình trước toà nếu có tranh chấp.
 - Chính sách phải được hỗ trợ và quản trị phù hợp.
- Các hướng dẫn về dạng thức của chính sách ATTT như sau:
 - Chính sách phải góp phần vào sự thành công của tổ chức.
 - Cấp quản lý phải đảm bảo việc chia sẻ đầy đủ trách nhiệm.
 - Người dùng cuối nên tham gia vào tiến trình phát triển chính sách.

Tóm lược chương:

- Chính sách là tuyên bố về quan điểm của tổ chức nhằm tác động và xác định các quyết định, hành động, đồng thời được dùng để kiểm soát các hành động của mọi người và phát triển các quy trình, thủ tục.
- Một chính sách có thể được xem xét như một bộ các quy tắc quy định hành vi chấp nhận được hoặc không thể chấp nhận trong tổ chức.
- Các chính sách phải chứa thông tin những gì được yêu cầu và những gì bị cấm, các hình phạt khi vi phạm, và về quy trình kháng nghị.
- Hướng dẫn hỗ trợ cho chính sách đến từ các tiêu chuẩn, thực hành, quy trình và các hướng dẫn.

Tóm lược chương:

- Cấp quản lý phải định nghĩa 3 loại chính sách ATTT:
 - Chính sách ATTT của doanh nghiệp, thiết lập định hướng chiến lược, phạm vi, mức độ của mọi nỗ lực bảo mật; EISP phải được dựa trên đó và hỗ trợ các tuyên bố sứ mệnh, tầm nhìn của tổ chức.
 - Các chính sách ATTT theo các vấn đề cụ thể (Issue-specific information security policies) sẽ cung cấp hướng dẫn cho mọi thành viên của tổ chức về việc sử dụng CNTT.
 - Các chính sách ATTT theo cách hệ thống cụ thể (System-specific information security policies) sẽ hướng dẫn lý và thông số kỹ thuật của công nghệ và hệ thống cụ thể.
- Để chính sách hiệu quả, nó phải được viết, phân phát, đọc, hiểu, đồng ý và thống nhất áp dụng cho những người mà nó dự định một cách phù hợp.

Tóm lược chương:

- Việc xây dựng chính sách ATTT thường tuân theo tiến trình thiết kế, viết, phê duyệt chính thức, và tích hợp vào các tiến trình quản lý. Tổ chức phải đảm bảo chính sách được phân phối, đọc và hiểu đúng, và mỗi nhân viên đồng ý tuân thủ. Cấp quản lý cũng phải đảm bảo chính sách phải được thực thi thống nhất và khách quan.
- Chính sách thường được phát triển sử dụng cách tiếp cận quản lý dự án giống như SDLC (vòng đời phát triển hệ thống), có nghĩa rằng phải được lập kế hoạch, cấp kinh phí phù hợp, quản lý tích cực bảo đảm hoàn thành đúng hạn và trong hạn mức ngân sách.

Tóm lược chương:

- Nỗ lực xây dựng chính sách gồm các giai đoạn:
 - giai đoạn khảo sát điều tra: để nhận được sự hỗ trợ từ lãnh đạo cấp cao và có được sự rõ ràng về các mục tiêu cũng như phân tích để thu thập các tài liệu tham khảo chính, bao gồm mọi chính sách hiện hành đang có.
 - giai đoạn thiết kế: tạo tài liệu chính sách thực tế.
 - giai đoạn thực hiện: tổ chức phải phân phối và đạt được sự thừa nhận về chính sách.
 - giai đoạn duy trì: giữ cho chính sách hiệu quả như một công cụ để đáp ứng các mối đe dọa đang thay đổi

Tóm lược chương:

- Quản lý chính sách có thể đạt được bằng các công cụ phần mềm hỗ trợ phát triển, thực thi và duy trì chính sách.
- Các cách tiếp cận khác để phát triển chính sách ATTT bao gồm tiếp cận Chính sách ATTT Dễ Dùng (Information Security Policies Made Easy) và tiếp cận của hướng dẫn NIST SP 800-18 – hướng dẫn phát triển các kế hoạch bảo mật cho các hệ thống thông tin.
- 3 nguyên nhân chung dẫn đến các hành vi thiếu đạo đức hoặc bất hợp pháp: thiếu hiểu biết, tai nạn và ý định.
- Sự răn đe có thể hiệu quả cho 3 khả năng sau: sợ bị phạt, khả năng bị bắt và xác suất áp dụng hình phạt.

Bài tập:

- Tìm các chính sách bảo mật mẫu đang được các tổ chức, doanh nghiệp sử dụng theo 2 loại EISP, ISSP.

So sánh các chính sách tìm được với khung chính sách đã trình bày trong chương này và đưa ra nhận xét.

Closing Case

Prior to the first meeting of the RWW Enterprise Policy Review Committee, Mike asked Iris to meet him in his office.

"You've convinced me that IT and InfoSec policy are tightly integrated," Mike said, motioning for Iris to sit down. "And you've convinced me that InfoSec policy is critical to this enterprise. Since we are each members of the Enterprise Policy Review Committee, I think we may want to coordinate our efforts when we bring issues up in that group. You agree?"

Iris, who knew how important policy was to her program's success, smiled.

"Sure, no problem," she said. "I see it the same way you do, I think."

"Good," Mike said. "We'll work together to make sure the EISP you've drafted is integrated with the other top-level enterprise policies. What we need to watch out for now is all the cross-references between the top-level policies and the second-tier and third-tier policies. The entire issue of internal consistency between supporting policies is a problem, especially with getting the HR department policies to integrate fully."

Iris nodded while Mike continued.

"I want you to take the current HR policy document binder and make a wish list of possible changes," he said. "You should focus on making sure we get the right references in place. If you can send me the change plan by the end of the weekend, I will have time to review it."

Iris smiled. "Will do, Mike!" she said. "But I can tell you, the first thing I'll recommend is that we toss these antique binders and look into an intranet policy administration application so we can move RWW into the 21st century!"

Discussion Questions

1. If the Enterprise Policy Review Committee is not open to the approach that Mike and Iris want to use for structuring InfoSec policies into three tiers, how should Mike and Iris proceed?
2. Should the CISO (Iris) be assessing HR policies? Why or why not?

Ethical Decision Making

Suppose that Iris sends Mike her detailed plan for an EISP along with a draft of a fully revised Enterprise IT Policy, with all of the necessary changes in the supporting policies. Suppose further that, during the Enterprise Policy Review Committee meeting, Mike submits the revised EISP exactly as Iris has revised it but does not include any reference to the work that Iris did. In fact, Mike presents the enhanced EISP as his own work. Has Mike broken any laws in representing Iris' policy work as his own? Has Mike committed an ethical lapse in doing so, or is he just being inconsiderate?